CYBER.AR

I CONGRESO DE CIBERDEFENSA ARGENTINA 2026

Facultad de Ingeniería del Ejército

UNDEF

Facultad Militar Conjunta

INSTITUTO DE CIBERDEFENSA DE LAS FUERZAS ARMADAS



Sobre el autor

A **Rol actual** Analista de Threat Intelligence · Threat hunter · Líder de SOC — Security Advisor (MSSP), Montevideo, Uruguay. Más de 15 años en ciberseguridad.

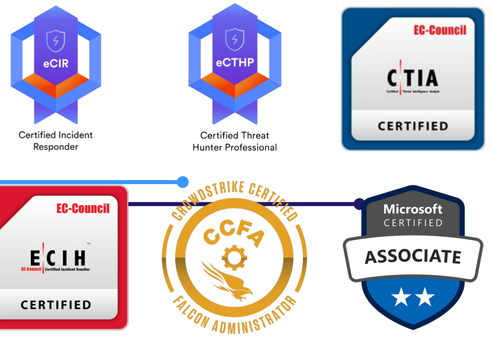
B **Trayectoria** SOC Analyst (L1, L2) → Phishing Analyst → Threat Intelligence e Incident Response.

C **Roles en el Estado** Reunion de Inforacion / Jefe Dpto Contra Inteligencia Criminal - Ministerio de Justicia Pcia Bs As

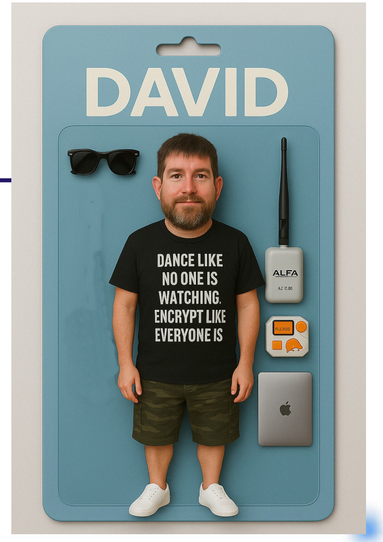
D **Temas que sigo** Threat Intelligence, ransomware, ecosistema de acceso inicial y economía de credenciales.

E **Certificaciones** eCIR · eCTHP (INE Security) · CTIA · ECIH (EC-Council) · CCFA (CrowdStrike) · SC-200 (Microsoft).

F **Contacto** @anakinswal · github.com/Ank1nskywalker/talks · perez.edav@gmail.com



Certificaciones



Agenda · 12 minutos · 7 bloques

01	**El problema** Llegamos tarde y mirando lo barato: el mercado de credenciales y la Pirámide del Dolor.	2'
02	**La metodología** Tres fases encadenadas del ciclo de inteligencia: qué es cada una y cómo se conectan.	1'
03	**Fase I · Recolección y evaluación** Dark Web, código Admiralty, OPSEC, PIR. La economía de credenciales, dos casos propios reportados al CERT.ar y el impacto local (Oldelval).	3'
04	**Fase II · Del indicador al comportamiento** MITRE ATT&CK y TTPs: por qué la defensa se ancla en cómo opera el adversario y no en sus artefactos.	1'
05	**Fase III · Atribución** Por qué importa, cómo se hace en tres niveles, por qué el mismo actor tiene siete nombres y qué codifica cada empresa.	3'
06	**La prueba** Caso RMM: del fraude al espionaje estatal. El Tesoro de EE.UU. recorriendo los tres niveles.	1'30
07	**Conclusiones** Anticipar al adversario; el juicio humano irreemplazable en la atribución.	30''

Fuente: tiempos orientativos; 3 minutos adicionales de preguntas al final.

Hoja de ruta

El problema

La ciberdefensa reacciona después del ataque y se apoya en indicadores baratos de reemplazar. Llega tarde y mira lo que menos le cuesta al adversario cambiar.

La propuesta: una metodología de CTI proactiva

Una metodología es el procedimiento de trabajo del analista para pasar, de forma replicable y trazable, del dato crudo al juicio de atribución. Es el aporte central del trabajo presentado a este congreso. Se organiza en tres fases encadenadas:

FASE I
Recolección y evaluación en la Dark Web

¿Qué se dice del adversario y cuánto vale ese dato?

→

FASE II
Del indicador al comportamiento

¿Cómo opera, más allá de sus artefactos?

→

FASE III
Atribución estructurada

¿Quién es, con qué confianza y quién puede afirmarlo?

La tesis: encadenar las tres fases permite anticipar al adversario antes del ataque. Y el juicio humano es irreemplazable en la atribución, donde el error tiene consecuencias estratégicas y políticas.

La prueba: dos casos documentados —abuso de herramientas legítimas y técnicas Living-off-the-Land— más dos casos regionales propios reportados al CERT.ar y un impacto local documentado (Oldelval, 2026).

Fuente: el problema, la propuesta y su validación en una página.

El problema, en vivo: esto está en venta hoy

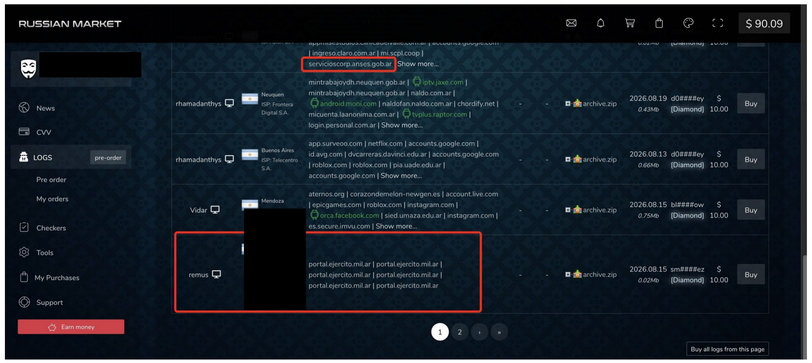
Un **broker de acceso inicial (IAB)** es quien revende accesos robados. Este vende paquetes de credenciales corporativas capturadas por infostealers.

Publica **dominio, país, fecha y precio**. No el usuario ni el endpoint: eso lo recibe el comprador al pagar.

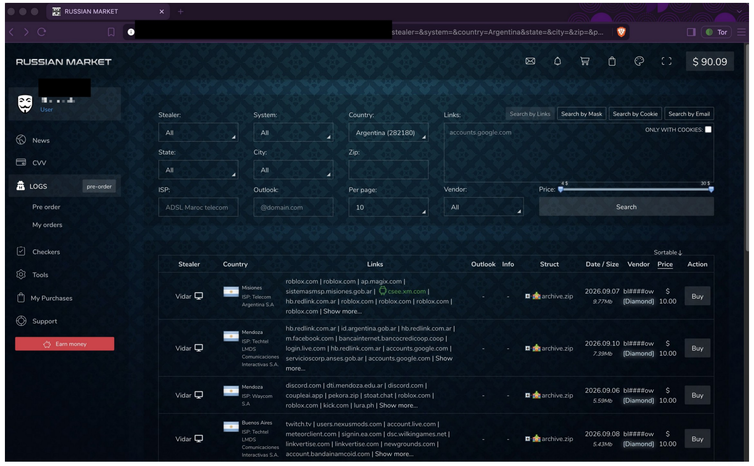
Filtrado por Argentina. En la lista: **portal.ejercito.mil.ar** y **armada.mil.ar**, desde **10 dólares**, con fecha de esta semana.

Así de accesible y así de barato empieza un ataque. De esto se defiende la charla.

Capturas sanitizadas: la Fase I exige OPSEC del analista (lo definimos en un momento).



Log con seis accesos a portal.ejercito.mil.ar · «remus» · 10 USD · 15/08/2026.



Buscador filtrado por país (Argentina) · rango de precio 4–30 USD.

Fuente: captura propia de un mercado de logs de infostealer (Russian Market), sep 2026; usuario de investigación y URL .onion sanitizados. El mercado publica dominio, país, fecha y precio —no el usuario ni el endpoint. Contexto: Hudson Rock (2025) [14].

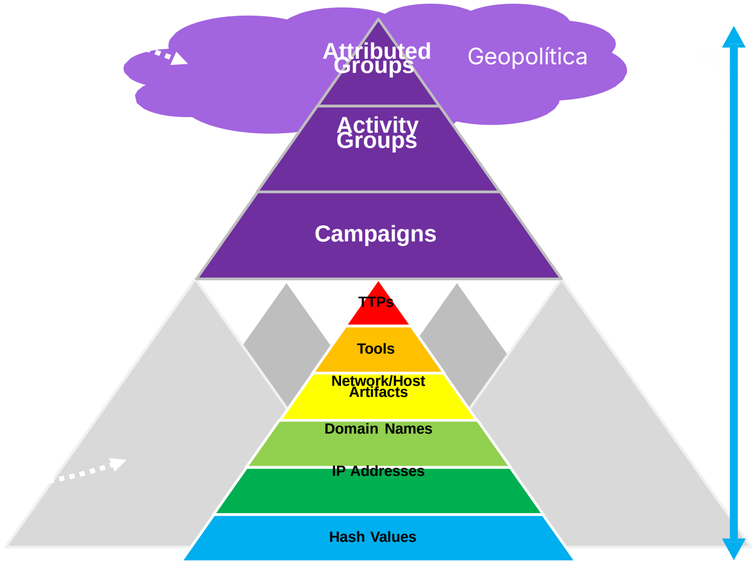
Por qué llegamos tarde y mirando lo barato

- La defensa reactiva detecta y responde después del incidente.
- Se apoya en **IOCs** —hashes, IPs, dominios—: indicadores atómicos, volátiles y baratos de reemplazar para el adversario.
- La **Pirámide del Dolor** [2] ordena los indicadores por cuánto le duele al atacante que se los bloqueen: abajo lo trivial de cambiar; arriba, su comportamiento.

Ascender del indicador al comportamiento es la condición para dejar de llegar tarde. Ese ascenso es la metodología.







Pirámide del Dolor, extendida con intención (Fase III) y geopolítica

Fuente: [1] Hutchins, Cloppert & Amin (2011) · [2] Bianco, D. J. (2013), The Pyramid of Pain, detect-respond.blogspot.com · extensión con intención y geopolítica de Gert-Jan Bruggink [32]; figura presentada por el autor en Ekoparty Miami 2026.

La metodología: tres fases encadenadas

Este es el aporte central del trabajo: no una técnica suelta, sino un flujo ordenado donde la salida de cada fase alimenta a la siguiente. Traslada al dominio cibernético el tradecraft de la inteligencia clásica y lo hace replicable y auditable. Lo que sigue lo expone y lo prueba con casos.



- **Fase I — la pregunta:** ¿qué se dice del adversario en el ecosistema criminal, y cuánto vale ese dato? Recolectar y, sobre todo, evaluar.
- **Fase II — la pregunta:** ¿cómo opera, más allá de los artefactos que rota en cada campaña? Del indicador al comportamiento.
- **Fase III — la pregunta:** ¿quién es, con qué confianza, y quién está habilitado a afirmarlo? La atribución: el corazón de la charla.

Fuente: Sección 2 del trabajo. La salida de cada fase es la entrada de la siguiente: un flujo continuo, no tres actividades sueltas.

Fase I · Recolección y evaluación en la Dark Web

La materia prima está en foros, mercados y canales del ecosistema criminal. El desafío no es encontrar datos: es no tratar todo rumor como un hecho. Tres disciplinas lo resuelven.

Código Admiralty
Cómo se califica un dato.

- Fiabilidad de la fuente: A–F.
- Credibilidad de la información: 1–6.
- Se califican por separado; el grado de confianza viaja con cada hallazgo. Ej.: C2 = fuente bastante fiable, dato probablemente cierto.

OPSEC
Seguridad operacional del analista.

- Identidades de investigación separadas.
- Infraestructura de acceso segmentada.
- No contaminar la fuente ni exponer la actividad de inteligencia. El analista no debe convertirse en un indicador del otro lado.

PIR
Requerimientos de inteligencia prioritarios.

- La recolección responde a decisiones pendientes de la organización.
- No se acumulan datos sin propósito.
- Primero las preguntas que importan (¿aparecen mis dominios, mis credenciales?), después se recolecta.

Fuente: código Admiralty: sistema de evaluación de fuentes de la OTAN (AJP-2.1). Detalle de las escalas en anexo.

Fase I aplicada · La economía de credenciales

El PIR más rentable para un Estado: vigilar credenciales institucionales expuestas. Así funciona la cadena.

Infostealer
roba credenciales

→

Log
(credenciales, cookies)

→

Broker de acceso
inicial (IAB)

→

Ransomware /
actor estatal

54 % de las víctimas publicadas en sitios de extorsión de ransomware ya tenían su dominio en logs de infostealer antes del ataque; el intervalo más frecuente entre exposición y ataque ronda los **dos días** [16].

Un dominio institucional —**.mil o su equivalente nacional**— en un log es **alerta temprana accionable**: rotar la credencial y bloquear el acceso antes de que el broker concrete la venta. Ahí las Fuerzas Armadas ganan tiempo al adversario.

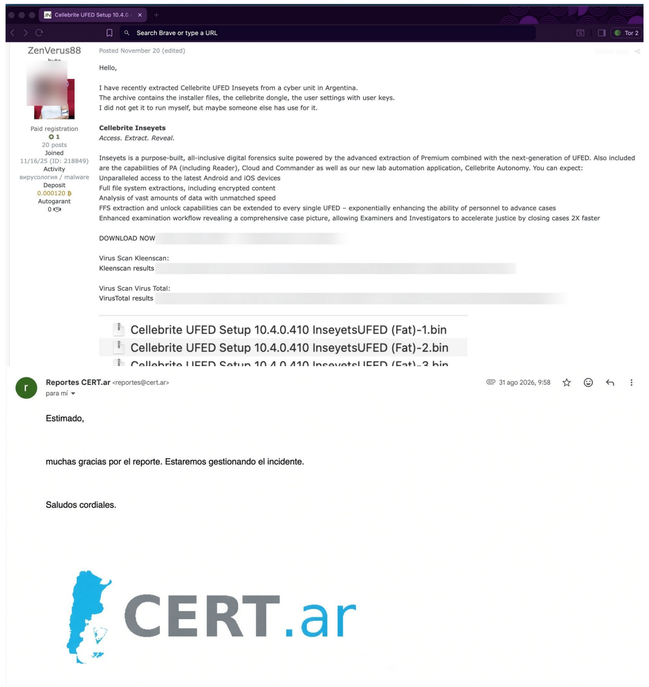
Búsqueda por dominio

En vivo si hay red; captura de respaldo si no.

Devuelve cuántas máquinas y credenciales por dominio están expuestas —sin exponer credenciales.

Fuente: [7] ENISA Threat Landscape 2024 · [16] Verizon DBIR 2025 · búsqueda por dominio: herramienta gratuita de Hudson Rock [14].

Fase I · Caso propio: la capacidad del Estado, a la venta



Post del vendedor (Foro Exploit.in) · acuse del CERT.ar al reporte.

El hallazgo

- **Software forense a la venta:** Cellebrite UFED Inseyets 10.4.0.410 —instalador, dongle y llaves de usuario— de una unidad Cyber en Argentina.
- **Log del equipo central de la Policía Federal Argentina:** credenciales y correos de servicios de gobierno.
- **Los dos vectores de la charla en un hecho:** herramienta legítima comprometida y economía de credenciales.

Fase I en acción — el ciclo completo

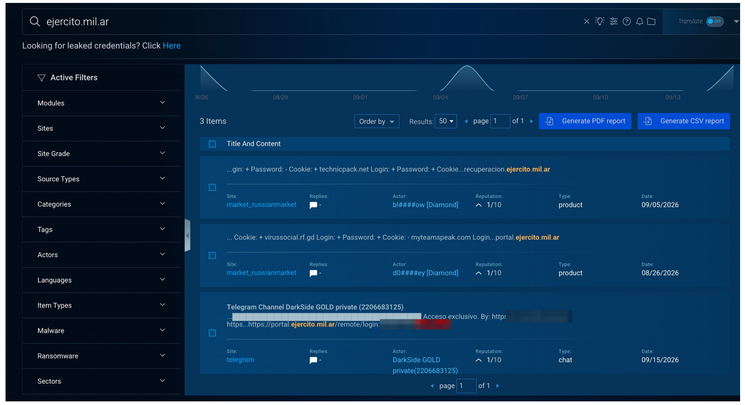
- **Evaluación (Admiralty):** fuente **C** (vendedor con historial acotado); información **2** (artefactos verificables, dominios reales; binario no verificado). Ejemplo real de la calificación que definimos antes.

Detección	Notificación	Respuesta
hallazgo en el foro	reporte al CERT.ar	acuse: «estaremos gestionando el incidente»

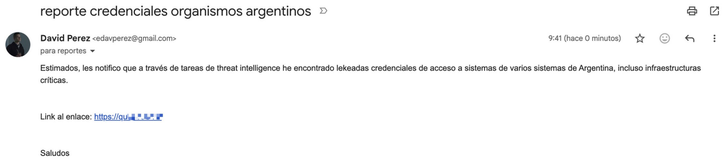
La alerta temprana de la Fase I, ejecutada en la región y con final: detectar, calificar y notificar la exposición de una capacidad del Estado.

Fuente: investigación propia del autor (2025–2026); reportado al CERT.ar. Capturas sanitizadas por OPSEC: dominios, enlaces, hashes e identificadores tapados.

Fase I · Caso propio II: FF.AA. e infraestructura crítica, hoy



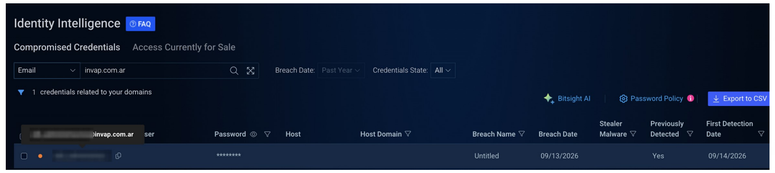
Búsqueda «ejercito.mil.ar» en la plataforma de CTI: el mismo portal del gancho, ahora también en un canal de Telegram, con fecha de ayer (15/09/2026).



Notificación del hallazgo al CERT.ar (16/09/2026), con enlace al reporte.

Detección	Notificación	Objetivo
hallazgo en plataforma, mercado y Telegram (13–15/09)	reporte al CERT.ar (16/09), antes de esta charla	rotación y bloqueo antes de la venta y la explotación

El hallazgo · 13 al 15 de septiembre de 2026



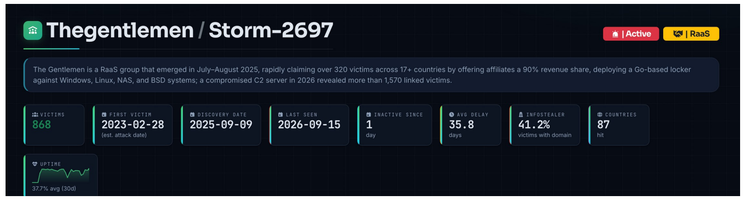
INVAP (invap.com.ar), infraestructura crítica: credencial corporativa comprometida por infostealer. Brecha 13/09 → detección 14/09: un día.

- **Ejército Argentino (.mil.ar):** credenciales y cookies de sesión —incluido un portal de acceso remoto— a la venta en Russian Market y difundidas en un canal de Telegram. El mercado no es el único canal.
- **INVAP, infraestructura crítica:** credencial corporativa expuesta por infostealer, detectada un día después de la brecha. La alerta temprana existe y es medible.
- **Distribución en cloud público:** combolists de cientos de MB alojados en MediaFire. No hace falta Tor: la barrera de entrada es trivial (detalle en anexo).
- **Acción:** hallazgos notificados al CERT.ar antes de esta presentación, para habilitar la rotación y el bloqueo antes de la venta y la explotación.

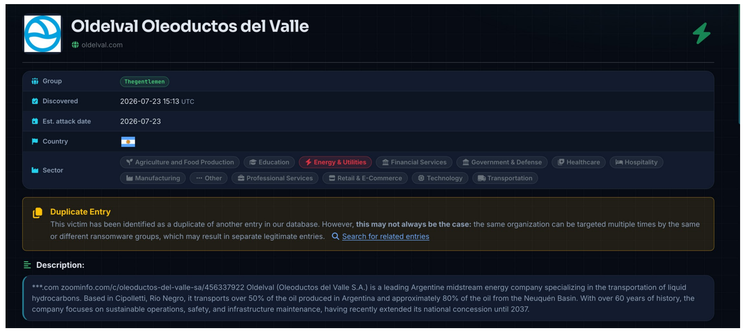
Lo que suma este caso: el PIR sobre dominios institucionales debe cubrir mercados, canales de Telegram y cloud público; y el «un día» de INVAP muestra que la alerta temprana es medible.

Fuente: capturas propias de plataformas de CTI e inteligencia de identidades (sep 2026); notificado al CERT.ar el 16/09/2026. Sanitizado por OPSEC: usuarios, tokens y enlaces de Telegram tapados.

Fase I · Del log al oleoducto: Oldelval y The Gentlemen (julio 2026)



Ficha del grupo en la plataforma (al 15/09/2026): RaaS activo, reparto del 90 % a afiliados; 41,2 % de las víctimas con dominio en logs de infostealer.



Ficha de la víctima: Oldelval (oldelval.com), Argentina, energía; reivindicada por The Gentlemen, 23/07/2026. La plataforma la marca como posible duplicado.

Credencial expuesta	Afiliado RaaS	Infraestructura crítica
log de infostealer → broker de acceso inicial (IAB)	compra el acceso; 90 % del rescate para él	ransomware en la transportista de Vaca Muerta

Qué pasó

- **Oldelval** —transportista troncal de Vaca Muerta (~75 % del crudo; YPF, 37 %)— sufrió ransomware reivindicado por The Gentlemen (RaaS, Storm-2697).
- **Informado a la CNV** como hecho relevante (31/07/2026). Afectó sistemas administrativos; el transporte de crudo no se interrumpió; sin rescate reportado.
- **Una semana antes, Ecopetrol** (Colombia): ~3.300 cuentas exfiltradas por el mismo grupo. Patrón regional sobre el sector energético.

El puente con la Fase I

- **Reparto del 90 %** a afiliados y reclutamiento de brokers de acceso inicial (acuerdo con BreachForums). Sus afiliados compran los accesos que vimos a la venta.
- **41,2 %** de sus víctimas con dominio ya figuraban en logs de infostealer (según la plataforma): la cadena del slide 9, terminando en un oleoducto argentino.

El actor era conocido, activo y rastreable; su cadena empieza en una credencial filtrada que se podía detectar antes. Eso es lo que la Fase I propone institucionalizar.

Fuente: hecho relevante de Oldelval ante la CNV (31/07/2026); Infobae, Ámbito, iProfesional (ago 2026); perfil del grupo: Microsoft Threat Intelligence (may 2026), Unit 42 (jul 2026). Caso público.

Fase II · Del indicador al comportamiento

Volvamos a la pirámide: la Fase I entregó hallazgos; la Fase II los sube del artefacto al comportamiento.

MITRE ATT&CK es el lenguaje estándar para describir ese comportamiento:

Táctica — el objetivo que persigue.

Técnica — el medio para lograrlo.

Procedimiento — la implementación concreta observada.

Un **TTP** es esa tríada. Es más estable que un dominio o un hash: por eso la detección anclada en TTPs sobrevive a la rotación de indicadores.

Táctica	Comando y control
Técnica	T1219 · Remote Access Software
Procedimiento	ScreenConnect portátil entregado por phishing

Ejemplo real: el mismo TTP —usar software de acceso remoto legítimo— aparece del fraude financiero al espionaje estatal. Los dominios de cada campaña se rotan; el comportamiento persiste.

Por eso la defensa se ancla en el comportamiento, no en el artefacto. Los casos de la Sección 3 lo muestran.

La priorización de qué TTP atacar primero sigue cinco criterios explícitos (costo de sustitución, transversalidad, exposición, observabilidad, alineación con PIR). Tabla completa en anexo.

Fuente: [3] Strom et al. (2018), MITRE ATT&CK: Design and Philosophy · criterios de priorización de TTPs: Tabla 1 (Sección 2.2.1), en anexo.

Fase III · La atribución: por qué importa

Llegamos al corazón de la charla. Atribuir es responder quién está detrás de la actividad. Antes del «cómo», el «para qué»:
¿Qué tiene que ver un Panda, un Oso (Bear), una Tormenta (Storm) o Neptuno con la ciberseguridad?. 🐼🐻⛈️

Táctico	Operacional	Estratégico
Bloquear, firmar, parchear lo que este adversario usa hoy.	Anticipar su próxima infraestructura y campaña conociendo cómo opera.	Evaluar el riesgo real para la organización y priorizar la inversión en defensa.

- **CrowdStrike:** «no tenés un problema de ransomware, tenés un problema de adversario». Conocer al adversario dice dónde defender y filtra el ruido a quien realmente te apunta.
- **Trend Micro:** tratar un nombre como un hecho «crea una falsa certeza que distorsiona prioridades». La atribución mal hecha es peor que no atribuir.
- **En ciberdefensa hay un plano más:** el político. Y ahí el error no es técnico, es riesgo de escalamiento. Por eso lo estructuramos en niveles.

Fuente: [24] Mandiant (2020) · [28] CrowdStrike (2022) · [27] TrendAI (2026). El «por qué» antes del «cómo».

Fase III · Cómo atribuir: tres niveles, tres umbrales

Nivel	Pregunta que responde	Evidencia típica	Confianza admisible	Quién puede afirmarlo
Técnico	¿Con qué herramientas e infraestructura se ejecutó?	Malware, infraestructura C2, TTPs, artefactos forenses	Alta a moderada	El analista
Operacional	¿Qué grupo o campaña está detrás?	Solapamiento de TTPs entre intrusiones, victimología, patrones	Moderada	El equipo, con revisión por pares
Político / estratégico	¿Quién la ordenó, patrocinó o toleró?	Contexto geopolítico, inteligencia de todas las fuentes	Baja a moderada	Excede al analista: decisión del Estado

La regla de oro

- **La confianza no se hereda:** una atribución técnica de confianza alta no autoriza a afirmar el nivel político con esa confianza.
- **El nivel político excede al analista.** En el caso del Tesoro (más adelante), solo se formalizó con acciones del Departamento de Justicia y sanciones.

ACH — cómo no equivocarse

Análisis de Hipótesis en Competencia (Heuer). En vez de confirmar la hipótesis preferida, se confrontan todas —incluida la de falsa bandera — contra la evidencia, y sobrevive la menos refutada.

Mitiga sesgo de confirmación, anclaje e imagen en espejo. Obligatorio antes de afirmar. Protocolo de 8 pasos en anexo.

Fuente: [4] Rid & Buchanan (2015) · [5] Heuer (1999), ACH · [8] ODNI, ICD 203. Tablas 2 y 3 del trabajo.

Fase III · ¿Por qué el mismo actor tiene siete nombres?

Un solo grupo. Siete empresas, siete nombres. No es capricho: es consecuencia de cómo se hace inteligencia.

- **Nadie ve lo mismo.** Google: «no hay dos organizaciones con la misma visibilidad». Cada vendor observa una porción distinta del actor.
- **Usar el nombre ajeno te ata a su evaluación.** Unit 42: adoptar el alias de otro acopla tu juicio a una definición que no controlás.
- **El nombre no es una atribución.** Es la etiqueta de un clúster de actividad. Por eso la Fase III separa el clúster (técnico) del juicio de quién está detrás (operacional/político).

Moraleja: cuando leas «Volt Typhoon» y «Voltzite», no son dos amenazas. Es una, vista por dos ojos distintos. Saberlo evita duplicar defensas y malgastar recursos.

VOLT TYPHOON
un actor estatal, siete etiquetas

Volt Typhoon Microsoft	**VANGUARD PANDA** CrowdStrike
BRONZE SILHOUETTE Secureworks	**Insidious Taurus** Unit 42
UNC3236 Mandiant	**Voltzite** Dragos
DEV-0391 Microsoft (previo)	

Fuente: alias según CISA AA24-038A [10] y la deconflicción Microsoft–CrowdStrike (jun 2025) [29]. [23] Google GTIG (jul 2026).

Fase III · Por qué cada empresa nombra distinto, y qué codifica

Si nadie ve lo mismo, cada uno construye su propio esquema. Y en el nombre codifican una hipótesis: de dónde viene el actor, o qué lo motiva.

Vendor	Esquema (ejemplo)	Codifica en el nombre
Microsoft	Clima + adjetivo (Silk Typhoon)	Origen (Typhoon = China) y motivación (Tempest = financiero)
CrowdStrike	Adjetivo + animal (Vanguard Panda)	Origen (Panda = China) y motivación (Spider = crimen)
Unit 42	Modificador + constelación (Stately Taurus)	Origen (Taurus = China) y motivación (Scorpius = ransomware)
TrendAI	Elemento + criatura (Earth Demon)	Solo motivación (Earth = espionaje). Evita afirmar origen a propósito
Dragos	Mineral (Voltzite)	Nada: neutro por diseño. No presume origen ni motivación

El cierre que ata todo con nuestra tesis

El sufijo de origen (Typhoon, Panda, Taurus) es un juicio de nexo geopolítico —el nivel operacional—, no una afirmación de patrocinio estatal. Ningún vendor emite el nivel político.

La industria resuelve los niveles técnico y operacional con este tradecraft. El nivel político —quién lo ordenó— sigue siendo del Estado. Eso es exactamente lo que propone la metodología.

Fuente: [21] Microsoft · [23] GTIG · [28] CrowdStrike · [25] Unit 42 · [27] TrendAI · [30] Secureworks · [31] Dragos. Tabla completa en anexo.

Prueba · Caso 1: RMM, del fraude al espionaje estatal

Un mismo comportamiento —abusar de software de administración remota (RMM) legítimo, técnica T1219— recorre todo el espectro de actores. Los dominios rotan; el TTP persiste.

Aviso conjunto CISA/NSA — enero 2023	Campaña de phishing entrega RMM portátil (ScreenConnect, AnyDesk); estafa de reembolso. Ya advierten posible uso por actores estatales.
CERT-UA — Ucrania, 2024–2025	Abuso reiterado de RMM contra el Estado y la infraestructura crítica; los atacantes llegan a hacerse pasar por el propio CERT-UA.
Vulnerabilidad crítica en ScreenConnect — feb 2024	Bypass de autenticación (CVE-2024-1709, severidad máxima). Explotación masiva por ransomware y actores estatales.
Tesoro de EE.UU. — diciembre 2024	Acceso remoto privilegiado (BeyondTrust) comprometido en la cadena de suministro. Actor estatal chino Silk Typhoon. Foco en la oficina de sanciones.

No se persigue el binario, se persigue el patrón. Escalada de impacto, no cronología. Detalle y códigos técnicos (CVE, avisos) en anexo.

Fuente: [9] CISA/NSA/MS-ISAC (2023) · [11][12] CERT-UA · [13] CISA KEV, CVE-2024-1709 · [15] Tesoro de EE.UU. & CISA.

Prueba · La atribución en acción: el caso del Tesoro

El caso del Tesoro recorriendo los tres niveles de atribución

Técnico	Clave de API comprometida en el servicio en la nube de BeyondTrust; dos vulnerabilidades explotadas; acceso a documentos no clasificados, foco en la oficina de sanciones (OFAC).
Operacional	Solapamiento de TTPs y victimología → actor estatal chino Silk Typhoon. (Antes HAFNIUM; el mismo clúster tiene otros alias según el vendor.)
Político	Patrocinio estatal: se formalizó solo con la atribución pública del gobierno de EE.UU. —Departamento de Justicia y sanciones—, con umbral y tiempo muy superiores.

Confirma la regla de oro: el político exigió un umbral muy superior al técnico. No se hereda.

Contrapunto · Volt Typhoon

El extremo opuesto del mismo argumento.

- **Living-off-the-Land (LOTL):** el actor usa herramientas nativas del sistema operativo. No despliega malware que firmar.
- Actor estatal atribuido a China, preposicionado en infraestructura crítica de EE.UU. (comunicaciones, energía, transporte, agua).
- Sin artefactos atómicos que detectar: la defensa depende del análisis de comportamiento (Fase II).

RMM = herramienta legítima externa. LOTL = herramienta legítima interna. Ninguno se detecta por IOC. Ambos exigen ascender al comportamiento.

Fuente: [15] Tesoro de EE.UU. & CISA (2024–2025) · [6][10] CISA/NSA/FBI (2024), Volt Typhoon. Los tres niveles de la Fase III sobre un caso real.

Conclusiones

I

Integrar las tres fases —Dark Web, comportamiento y atribución— configura un marco para anticipar al adversario antes del ataque y elevar su costo.

II

Ascender del indicador al comportamiento no es opcional: es la condición para detectar a quien rota su infraestructura o usa herramientas legítimas del propio entorno.

III

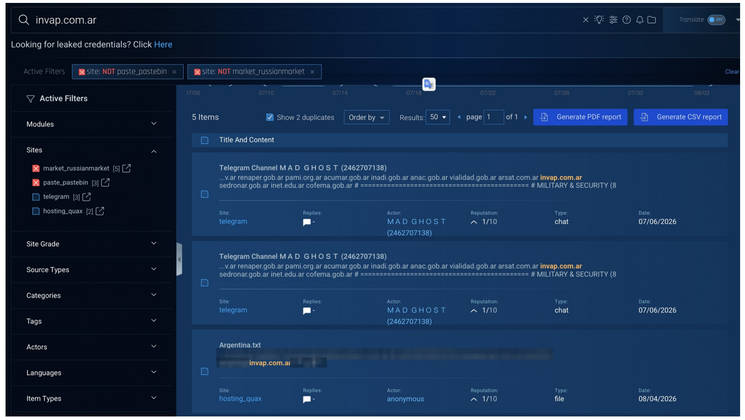
El monitoreo proactivo de credenciales de defensa e infraestructura crítica, con alerta temprana, es un requerimiento de inteligencia prioritario para el Estado y las FF.AA.

El juicio humano es irreemplazable en la atribución. La industria resuelve lo técnico y lo operacional; el nivel político —donde el error escala— sigue siendo del Estado.

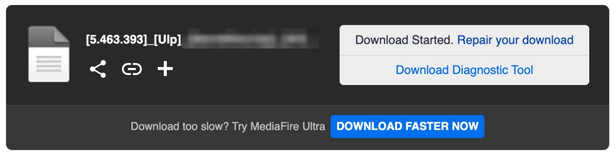
Línea de trabajo: sistematizar casuística regional, definir métricas prospectivas y sostener la aplicación con línea base operativa.

Fuente: Sección 4 del trabajo (camera-ready).

Anexo · Evidencia ampliada: targeting sobre Argentina

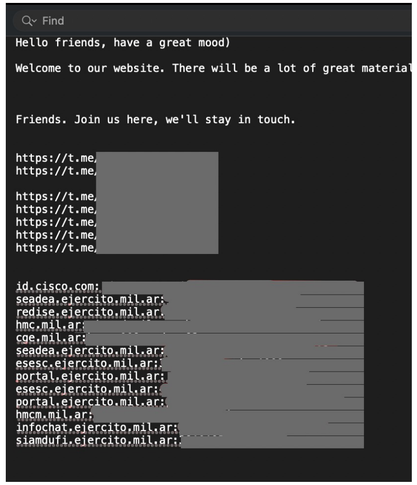


Canal de Telegram «MAD GHOST» (07/2026): organismos argentinos objetivo (renaper, pami, anac, vialidad, arsat, invap, sedronar, inet…), con sección «Military & Security».





Dump ULP (URL:login:password) de 242,67 MB en MediaFire, subido el 23/08/2026. Cloud público, sin Tor.



Combolist crudo, distribuido junto a invitaciones de Telegram: pared de subdominios ejercito.mil.ar y .mil.ar con credenciales (tapadas).

Qué muestra

- **Tres canales,** no uno: mercado, Telegram y cloud público.
- **Superficie institucional:** organismos, FF.AA. y proveedores estratégicos aparecen juntos.
- **Barrera trivial:** descargar un .txt.

Lo que enseña

- **El PIR** sobre dominios institucionales debe cubrir los tres canales, no solo los mercados.
- **Admiralty:** canal de Telegram y combolist son fuente de baja fiabilidad hasta verificar; la detección propia en la plataforma de identidades (INVAP) confirma el dato y eleva su credibilidad.
- **Acción:** lo verificado se notifica (slide 11); lo no verificado queda como indicador de seguimiento.

Fuente: capturas propias (jul–sep 2026): canal de Telegram, combolist y hosting público. Sanitizado por OPSEC: usuarios, credenciales, enlaces de Telegram y dominio de distribución tapados. Respaldo del slide 11.

MUCHAS GRACIAS

David Pérez · perez.edav@gmail.com · @anakinswal

Trabajo, deck y fuentes: github.com/Ank1nskywalker/talks



Anexo · Operation Endgame: cadena mixta público-privada

May 2024	Fase inicial coordinada por Europol y Eurojust contra cargadores de malware. Participa el Defense Criminal Investigative Service de EE.UU.
Abr 2025	Cinco detenciones; identificación de clientes de la botnet Smokeloader desde una base de datos incautada [20].
May 2025	Neutralización de «initial access malware»; veinte objetivos con órdenes internacionales [17].
Nov 2025	1.025 servidores dados de baja: Rhadamanthys, VenomRAT, Elysium.
Jun 2026	SocGholish, Amadey, StealC: ~27 millones de credenciales recuperadas y notificadas a titulares [19].

Por qué importa acá

- No es una operación policial pura: participan empresas privadas de CTI (Microsoft, ESET, Proofpoint, IBM X-Force, Bitsight). Responde a «¿qué hace acá un analista privado?».
- La inteligencia sobre credenciales se convirtió en notificación al afectado y rotación antes de la explotación: el mecanismo que la Fase I propone institucionalizar.
- IOCTA 2025: los brokers de acceso inicial publicitan cada vez más sus servicios en plataformas criminales [18].

Fuente: [17] Europol (may 2025) · [18] Europol, IOCTA 2025 · [19] Europol (jun 2026) · [20] Europol (abr 2025).

Anexo · Código Admiralty (sistema OTAN de evaluación)

Fiabilidad de la fuente	Credibilidad de la información
A · Completamente fiable	1 · Confirmada por otras fuentes
B · Habitualmente fiable	2 · Probablemente cierta
C · Bastante fiable	3 · Posiblemente cierta
D · No habitualmente fiable	4 · Dudosa
E · No fiable	5 · Improbable
F · No puede juzgarse	6 · No puede juzgarse

- Las dos escalas se califican por separado: una fuente muy fiable puede aportar un dato no confirmado (A3); una dudosa, un dato confirmado por otras vías (D1).
- La calificación viaja con el hallazgo hasta la Fase III, donde pondera el peso de cada evidencia en la matriz ACH.

C2

caso UFED / PFA

Fuente bastante fiable (C): vendedor de foro con historial acotado. Información probablemente cierta (2): artefactos verificables, dominios reales, sin verificación independiente del binario. Calificación del autor.

Fuente: Sistema OTAN de evaluación de fuentes (AJP-2.1). Ejemplo aplicado al caso UFED/PFA (slide 10).

Anexo · Protocolo ACH en ocho pasos

1	Enumerar hipótesis mutuamente excluyentes. La falsa bandera es de inclusión obligatoria.
2	Listar evidencia y supuestos, incluidas las ausencias significativas.
3	Construir la matriz evidencia × hipótesis; ponderar cada ítem con Admiralty.
4	Depurar la evidencia sin poder diagnóstico: lo consistente con todo no discrimina.
5	Ordenar por evidencia inconsistente: sobrevive la hipótesis menos refutada.
6	Identificar la evidencia bisagra: la que, si cambia, altera el orden.
7	Definir indicadores de seguimiento para reevaluar ante evidencia nueva.
8	Consignar con lenguaje de confianza qué evidencia modificaría la conclusión.

Obligatorio antes de afirmar atribución operacional o política. Revisión por pares ajenos a la hipótesis inicial.

Fuente: Sección 2.3.1, adaptado de Heuer [5]; lenguaje de confianza según ICD 203 [8].

Anexo · Criterios de priorización de TTPs (Tabla 1)

Criterio	Pregunta operativa	Función
Alineación con PIR	¿Responde a una decisión pendiente de la organización?	Filtro de entrada
Costo de sustitución	¿Cuánto le cuesta al adversario abandonar el comportamiento?	Determina el orden
Transversalidad	¿Cuántas categorías de actor usan el mismo TTP?	Determina el orden
Exposición del entorno	¿Existe la superficie de ataque en la organización?	Habilitante
Observabilidad	¿La telemetría permite detectarlo hoy?	Modulador: si falta, genera requerimiento de instrumentación

- El PIR filtra la entrada; costo de sustitución y transversalidad determinan el orden; la exposición habilita; la observabilidad modula.
- Escala ordinal, registrada y auditable; la calibración entre criterios es de cada organización.

Fuente: Sección 2.2.1. Aplicación: T1219 y la familia LOTL obtienen prioridad alta.

Anexo · Taxonomías por vendor (tabla completa)

Vendor	Esquema	Categorías codificadas	Temporal	Política de atribución
Microsoft	Clima + adjetivo	Origen: Typhoon (China), Blizzard (Rusia), Sandstorm (Irán). Motivación: Tempest (financiera)	Storm-####	Nombre solo con alta confianza en infra, herramientas, victimología y motivación
Google GTIG	Palabra + categoría	Origen: CASTLE (RPC), RELIC (Rusia), ION (Irán). Tipo: COMET (crimen)	UNC####	UNC → TEMP → nombrado; conserva alias; años de recolección
CrowdStrike	Adjetivo + animal	Origen: BEAR, PANDA, KITTEN. Motivación: SPIDER (crimen), JACKAL (hacktivismo)	clúster interno	Nexo geopolítico; ACH y lenguaje estimativo; revisión extendida
Unit 42	Modificador + constelación	Origen: Taurus (China), Ursa (Rusia). Motivación: Scorpius (ransomware), Libra (crimen)	CL-/TGR-####	Diamond Model, ≥6 meses, Admiralty, review board
TrendAI	Elemento + criatura	Solo motivación: Earth (espionaje), Water (financiera), Fire (destructiva)	SHADOW-###	Diamond + Admiralty + ACH; «un SHADOW no es una atribución»
Secureworks	Metal + palabra	Origen: BRONZE (China), IRON (Rusia). Motivación: GOLD (financiera)	—	Threat Group ≠ Threat Actor; feed de alias
Dragos	Mineral raro	Neutro: no codifica origen ni motivación	—	Diamond Model; no estandariza; advierte contra las piedras Rosetta

Fuente: [21] Microsoft · [23] GTIG · [24] Mandiant · [25] Unit 42 · [27] TrendAI · [28] CrowdStrike · [30] Secureworks · [31] Dragos.

Anexo · Referencias [1]–[11]

[1] Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). Intelligence-Driven Computer Network Defense... Intrusion Kill Chains. Lockheed Martin.
[2] Bianco, D. J. (2013, act. 2014). The Pyramid of Pain. Enterprise Detection & Response. https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html
[3] Strom, B. E. et al. (2018). MITRE ATT&CK: Design and Philosophy. The MITRE Corporation.
[4] Rid, T., & Buchanan, B. (2015). Attributing Cyber Attacks. Journal of Strategic Studies, 38(1-2), 4-37.
[5] Heuer, R. J. (1999). Psychology of Intelligence Analysis. Center for the Study of Intelligence, CIA.
[6] CISA, NSA, FBI et al. (2024). Identifying and Mitigating Living off the Land Techniques. Joint Guidance.
[7] ENISA (2024). ENISA Threat Landscape 2024.
[8] ODNI (2015). Intelligence Community Directive 203: Analytic Standards.
[9] CISA, NSA & MS-ISAC (2023). Protecting Against Malicious Use of RMM Software. Advisory AA23-025A.
[10] CISA, NSA, FBI et al. (2024). PRC State-Sponsored Actors... U.S. Critical Infrastructure. Advisory AA24-038A.
[11] CERT-UA & CSIRT-NBU (2024). Attacks Abusing SuperOps RMM (UAC-0188). cip.gov.ua.

Fuente: numeración: [1]–[20] del trabajo camera-ready; [21]–[32] fuentes de los slides de atribución.

Anexo · Referencias [12]–[22]

[12] CERT-UA (2025). AnyDesk Requests Impersonating CERT-UA Under a «Security Audit» Pretext.

[13] CISA (2024). CVE-2024-1709: ConnectWise ScreenConnect Authentication Bypass. KEV Catalog.

[14] Hudson Rock (2025). Infostealer-Compromised Credentials of U.S. Military and Defense Contractors. (Infosecurity Magazine, 2026).

[15] U.S. Dept. of the Treasury & CISA (2024–2025). Compromise of BeyondTrust via CVE-2024-12356 / -12686, attributed to Silk Typhoon (APT27/Hafnium). CISA KEV; U.S. DoJ.

[16] Verizon (2025). 2025 Data Breach Investigations Report (DBIR).

[17] Europol (2025). Operation ENDGAME Strikes Again. Semana de acción 19–22 may 2025.

[18] Europol (2025). IOCTA 2025 — Internet Organised Crime Threat Assessment.

[19] Europol (2026). Global Cyber Strike Disrupts SocGholish, Amadey, and StealC. 24 jun 2026.

[20] Europol (2025). Operation Endgame Follow-Up: Five Detentions and Server Takedowns. Abril 2025.

[21] Microsoft (2023, act. 2025). Microsoft shifts to a new threat actor naming taxonomy. https://www.microsoft.com/en-us/security/blog/2023/04/18/microsoft-shifts-to-a-new-threat-actor-naming-taxonomy/

[22] Microsoft Learn. How Microsoft names threat actors. https://learn.microsoft.com/en-us/unified-secops/microsoft-threat-actor-naming

Fuente: numeración: [1]–[20] del trabajo camera-ready; [21]–[32] fuentes de los slides de atribución.

Anexo · Referencias [23]–[32]

[23] Google Threat Intelligence Group (2026). Updated Cyber Threat Actor Naming System. 24 jul 2026. https://cloud.google.com/blog/topics/threat-intelligence/updated-cyber-threat-actor-naming-system

[24] Mandiant (2020). DebUNCing Attribution: How Mandiant Tracks Uncategorized Threat Actors. https://cloud.google.com/blog/topics/threat-intelligence/how-mandiant-tracks-uncategorized-threat-actors

[25] Unit 42 (2025). Introducing Unit 42's Attribution Framework. https://unit42.paloaltonetworks.com/unit-42-attribution-framework/

[26] Unit 42 (2022, act. 2025). Unit 42 Threat Group Naming Update. https://unit42.paloaltonetworks.com/unit-42-threat-group-naming-update/

[27] TrendAI (2026). Threat Attribution Framework: Structure Over Speculation. https://www.trendaisecurity.com/en-us/resources-insights/deep-research/threat-attribution-framework-how-trendai-applies-structure-over-speculation

[28] CrowdStrike (2022). Naming Adversaries and Why It Matters to Your Security Team. https://www.crowdstrike.com/en-us/blog/naming-adversaries-and-why-it-matters-to-security-teams/

[29] CrowdStrike & Microsoft (2025). Collaborate to Harmonize Cyber Threat Attribution. https://www.crowdstrike.com/en-us/press-releases/crowdstrike-microsoft-collaborate-deconflict-cyber-threat-attribution/

[30] Secureworks CTU (Sophos). Counter Threat Unit Researchers Publish Threat Group Definitions. https://www.sophos.com/en-us/blog/counter-threat-unit-researchers-publish-threat-group-definitions

[31] Dragos (2019, act. 2025). Uncovering ICS Threat Groups. https://www.dragos.com/blog/webinar-summary-uncovering-ics-threat-activity-groups/

[32] Bruggink, G.-J. (2023). Extended Pyramid of Pain — extensión de la Pirámide del Dolor de Bianco con las capas de intención y geopolítica. https://www.linkedin.com/in/gertjanbruggink/ · presentada por el autor en Threat Intelligence 101, Ekoparty Miami 2026 (github.com/Ank1nskywalker/talks).

Fuente: numeración: [1]–[20] del trabajo camera-ready; [21]–[32] fuentes de los slides de atribución.